

TP4 — Monitoring, FinOps & Sécurité

piloter l'exploitation de l'environnement Azure de
ShopEasy

Superviser avec **Azure Monitor** et **Log Analytics**, créer des **alertes**,
analyser les coûts (**FinOps**), conduire une **revue de sécurité**, **auditer** les
changements et produire une **note de recommandations DSI**.

Binôme

Louis SCARFONE

Maxence BOURRAGUÉ

Cadre

Mastère Dev Manager Full Stack — RNCP ni-
veau 7

Cas fil rouge : **ShopEasy**

Azure for Students — région swedencentral

9

ateliers + quiz

4

pilliers d'exploitation

≈ 47 \$

coût mensuel estimé

Sommaire

Table des matières

1	Atelier 1 — Cadrer les indicateurs d'exploitation	2
1.1	Tableau des indicateurs priorités	3
1.2	Questions guidées	4
2	Atelier 2 — Préparer l'environnement Azure Monitor	5
2.1	Ressources à identifier	5
2.2	Création du Log Analytics Workspace	6
2.3	Diagnostic settings — raccordement au workspace	6
2.3.1	Storage Account → workspace	7
2.3.2	Activity Log (abonnement) → workspace	7
2.3.3	VM — métriques disponibles sans agent	7
2.4	Justification des choix	8
2.5	Capture	8
3	Atelier 3 — Superviser les machines virtuelles	9
3.1	État des VM (inventaire)	9
3.2	Métriques observées (Azure Monitor)	10
3.3	Questions d'analyse	10
3.4	Tableau d'analyse des VM	11
3.5	Capture	12
4	Atelier 4 — Créer des alertes opérationnelles	13
4.1	Alertes retenues	13
4.2	Action Group — qui est notifié et comment	13
4.3	Création des alertes (Azure CLI)	14
4.4	Fiches d'alerte (livrable)	14
4.4.1	Fiche 1 — CPU élevé VM web	15
4.4.2	Fiche 2 — VM indisponible	15
4.5	Questions d'analyse	15
4.6	Captures	16
5	Atelier 5 — Construire un tableau de bord d'exploitation	17
5.1	Approche retenue — un dashboard Azure réel	18
5.2	Les 9 tuiles du dashboard	18
5.3	Couverture du contenu minimal de l'énoncé	19
5.4	Capture — dashboard Azure réel	20
5.5	Pourquoi ce tableau de bord	20
6	Atelier 6 — Analyse FinOps	21
6.1	Analyse des coûts	21

6.2	Politique de tags de gouvernance	22
6.3	Tableau d'optimisation FinOps	23
6.4	Budget mensuel (50 \$) — design et mise en œuvre	23
6.5	Questions d'analyse	24
6.6	Capture	25
7	Atelier 7 — Revue de sécurité Azure	25
7.1	Points de contrôle	26
7.2	Contrôle RBAC	26
7.3	Contrôle NSG	27
7.4	Exposition, chiffrage et recommandations	27
7.5	Matrice de risques sécurité	28
7.6	Points forts déjà en place	28
7.7	Captures	29
8	Atelier 8 — Audit des changements et Activity Log	30
8.1	Exploration de l'Activity Log	30
8.2	Synthèse par catégorie (travail demandé)	31
8.3	Fiche d'audit — trois événements significatifs	31
8.4	Questions d'analyse	32
8.5	Capture	33
9	Atelier 9 — Plan d'amélioration avant production (note DSI)	34
9.1	Contexte et objectif	34
9.2	État actuel de l'exploitation	34
9.3	Alertes et monitoring proposés	34
9.4	Analyse FinOps	34
9.5	Analyse sécurité	34
9.6	Risques résiduels	35
9.7	Plan d'action priorisé	35
9.8	Conclusion	36
10	Quiz de validation	36

1 Atelier 1 — Cadrer les indicateurs d'exploitation

🎯 **Objectif** — avant de configurer un outil, définir **quoi surveiller** pour ShopEasy : couvrir la disponibilité, la performance, les coûts et la sécurité.

📋 **Livrable attendu** — un tableau d'indicateurs **priorisés**, avec un seuil proposé et une justification claire pour chaque indicateur retenu.

Le cadrage s'appuie sur l'environnement réel hérité des TP précédents : Load Balancer lb-shopeasy-dev-web, deux VM Standard_B2ats_v2 (burstable, Ubuntu + Nginx), NSG nsg-shopeasy-dev-web, Storage shopeasydevdocsczvc1s, le tout en swedencentral pour ≈ 47 \$/mois.

1.1 Tableau des indicateurs priorités

Domaine	Indicateur	Seuil proposé	Priorité	Justification
Disponibilité	Disponibilité des backends du Load Balancer (sonde HTTP)	< 100 % des backends sains sur 5 min	Haute	Indicateur le plus proche du client : si une VM ne répond plus à la sonde, le site se dégrade — à détecter avant l'utilisateur.
Disponibilité	État d'alimentation des VM (PowerState)	VM stopped/deallocated inattendue	Moyenne	Une VM web éteinte hors plan = perte de capacité ou indisponibilité.
Performance	CPU moyen des VM (Percentage CPU)	> 80 % en moyenne sur 5 min	Haute	Détecte une saturation calcul soutenue avant dégradation des temps de réponse (seuil bien au-dessus de la baseline au repos).
Performance	Crédits CPU restants (CPU Credits Remaining)	Tendance vers 0	Moyenne	Spécifique au burstable B2ats_v2 : crédits épuisés → la VM est bridée même sans saturation apparente.
Coût	Coût mensuel cumulé vs budget	> 80 % puis 100 % du budget (50 \$)	Haute	Détecte une dérive budgétaire en cours de mois, à temps pour réagir.
Coût	Ressources sans tag / orphelines (disques, IP)	> 0 ressource	Moyenne	Coût non imputable ou facturé à vide (LB + IP facturés même sans trafic).
Sécurité	Ports d'administration exposés à Internet (NSG : 22/3389 depuis 0.0.0.0/0)	Toute règle source Internet sur 22/3389	Haute	Un port d'administration ouvert = scans et force brute permanents ; vérifie que SSH reste limité à l'IP admin.
Sécurité	Accès public au Storage / droits Owner excessifs	allowBlobPublic Access = true ou trop d'owner	Moyenne	Fuite de documents (RGPD) et non-respect du moindre privilège.
Exploitation	Nombre d'alertes critiques actives	> 0 alerte critique	Haute	Vision immédiate de l'état de santé : combien d'incidents en cours ?
Exploitation	Couverture monitoring (ressources critiques avec diagnostics/logs)	< 100 % des ressources critiques	Moyenne	Une ressource sans logs est un angle mort : rien à analyser après un incident.

1.2 Questions guidées

1. Pourquoi ne faut-il pas surveiller uniquement le CPU ?

Le CPU ne couvre qu'un seul axe (la saturation calcul). Un service peut être défaillant avec un **CPU normal** : VM allumée mais Nginx tombé, Load Balancer mal configuré, disque plein, mémoire saturée, base injoignable, crédits CPU épuisés, coût qui dérive, port exposé. Surveiller uniquement le CPU laisse des angles morts sur la disponibilité, la capacité, le coût et la sécurité. Une VM web au repos affiche d'ailleurs un CPU de l'ordre de **0,3 %** (mesuré à l'Atelier 3) — une valeur « saine » qui ne dirait rien d'un site KO ou d'une facture qui grimpe.

2. Quels indicateurs permettent de détecter un risque de saturation ?

Les indicateurs de capacité et de performance : **CPU moyen** soutenu, **crédits CPU restants** (déterminant sur le burstable B2ats_v2), **mémoire disponible** basse, **espace disque utilisé** (> 85 %, logs Nginx), **IOPS/débit disque** proche du plafond, et le **nombre de connexions/requêtes**. On surveille la **tendance vers la limite**, pas seulement la valeur instantanée.

3. Quels indicateurs permettent d'identifier une dérive de coûts ?

Le **coût cumulé du mois vs budget** (alerte 80 %/100 %), le **coût prévisionnel** (forecast), le **coût par service/par tag**, les **ressources sans tag** (coût non imputable), les **ressources orphelines** (disques/IP non attachés) et les **ressources facturées à vide** (Load Balancer, IP publiques ≈ 29 \$/mois). Sans tags ni budget, la hausse se constate trop tard, sur la facture.

4. Quels signaux permettent de détecter un problème de sécurité ?

Les **règles NSG ouvertes** sur Internet (surtout 22/3389), l'**accès public au Storage**, les **attributions de rôle excessives** (Owner), les **modifications sensibles dans l'Activity Log** (droits, règles réseau, suppressions), les **recommandations Defender/Advisor** et le **Secure Score**, les **authentifications échouées** (force brute) et l'**absence de logs** sur une ressource critique.

5. Quelle différence entre un incident, une alerte et une recommandation ?

Notion	Nature	Exemple ShopEasy
Recommandation	Proposition d'amélioration priorisée , préventive	« Restreindre les ports d'administration », « créer un budget ».
Alerte	Signal automatique déclenché par une condition franchie, actionnable	« CPU > 80 % depuis 5 min », « VM indisponible ».
Incident	Événement qui dégrade ou interrompt réellement le service	« Le site renvoie des erreurs », « une VM est tombée ».

La recommandation **réduit la probabilité** d'un incident, l'alerte le **détecte au plus tôt** (et le transforme en action), l'incident est ce que l'on cherche à éviter. Une alerte qui n'appelle aucune action n'est pas une alerte mais une simple information de tableau de bord.

✓ État après l'atelier

- Tableau d'indicateurs **priorisés** couvrant les 5 domaines (Disponibilité, Performance, Coût, Sécurité, Exploitation), chacun avec seuil et justification ancrés dans l'environnement réel de ShopEasy.
- Réponses aux 5 questions guidées.

- Atelier **conceptuel** : le livrable est ce tableau de cadrage. Aucune capture d'écran n'est attendue (aucun outil n'est encore configuré).
- **Prêt pour l'Atelier 2 — Préparer l'environnement Azure Monitor.**

2 Atelier 2 — Préparer l'environnement Azure Monitor

🎯 **Objectif** — mettre en place la base de l'observabilité Azure : un espace **Log Analytics**, des **diagnostics** et une organisation claire des ressources.

📦 **Livrable attendu** — description de l'espace Log Analytics, **liste des ressources connectées ou à connecter**, et justification des choix.

2.1 Ressources à identifier

L'environnement ShopEasy a été redéployé à l'identique depuis le Terraform du TP2 (terraform apply → 21 objets). Repérage des ressources :

>_ **bash**

```
az account show --query "{name:name, state:state}" -o table
az resource list --resource-group rg-shopeasy-dev --output table
```

>_ **console**

Name	State
-----	-----
Azure for Students	Enabled

Ressource attendue	Présence	Détail
Groupe de ressources	✓	rg-shopeasy-dev (swedencentral)
Machines virtuelles	✓	vm-shopeasy-dev-web-1/2 (Standard_B2ats_v2)
Network Security Groups	✓	nsg-shopeasy-dev-web
Storage Account	✓	shopeasydevdocsczvc1s (privé, versionné)
Réseau virtuel	✓	vnet-shopeasy-dev (10.20.0.0/16, subnet snet-web)
Base de données	⚠	Non déployée : cible TP1, hors périmètre Terraform du TP2. Traitée en proposition (Atelier 5).
Monitoring existant	⚠	Aucun au départ → le workspace est créé dans cet atelier.

13 ressources de premier niveau ; aucune ressource d'observabilité préexistante, d'où la nécessité de centraliser.

2.2 Création du Log Analytics Workspace

>_ bash				
<pre>az monitor log-analytics workspace create \ --resource-group rg-shopeasy-dev \ --workspace-name law-shopeasy-dev \ --location swedencentral \ --tags Application=shopeasy Environment=dev Owner=cloudops-shopeasy \ CostCenter=cloud-training ManagedBy=cli</pre>				
>_ console				
Nom	Region	SKU	RetentionJours	Etat
law-shopeasy-dev	swedencentral	PerGB2018	30	Succeeded

La région est **swedencentral** (et non francecentral comme dans l'exemple de l'énoncé) : francecentral est bloquée par la policy *Allowed regions d'Azure for Students*. Le workspace law-shopeasy-dev : SKU **PerGB2018** (facturation à l'ingestion), rétention **30 jours**, état Succeeded.

2.3 Diagnostic settings — raccordement au workspace

Pour chaque ressource critique, vérification de ce qui **peut** être envoyé vers Log Analytics, puis raccordement de ce qui est réalisable :

Ressource	Diagnostics attendus	Intérêt opérationnel	Statut
VM (web-1, web-2)	Métriques plateforme (CPU, réseau, disque, crédits CPU) ; logs système	Détecter surcharge et indisponibilité	Métriques natives OK ; logs invité à connecter (AMA + DCR)
Storage Account	Transactions (métrique), logs data-plane	Surveiller activité et coûts	✅ Connecté : diag-storage-to-law + diag-blob-to-law
Azure SQL	CPU, DTU/vCore, connexions	Détecter saturation base	Non déployé → à connecter si la base est provisionnée
Activity Log	Opérations administratives, sécurité	Auditer les changements	✅ Connecté : activitylog-to-law

Storage Account → workspace

```
>_ bash

STORAGE_ID=$(az storage account show -g rg-shopeasy-dev -n shopeasydevdocsczvc1s --query id -o tsv)
LAW_ID=$(az monitor log-analytics workspace show -g rg-shopeasy-dev -n law-shopeasy-dev --query id -o
↪ tsv)

# Metrique Transaction (activite et couts) au niveau du compte
az monitor diagnostic-settings create --name "diag-storage-to-law" \
  --resource "$STORAGE_ID" --workspace "$LAW_ID" \
  --metrics ' [{"category": "Transaction", "enabled": true}] '

# Logs data-plane (acces read/write/delete) au niveau du Blob service
az monitor diagnostic-settings create --name "diag-blob-to-law" \
  --resource "$STORAGE_ID/blobServices/default" --workspace "$LAW_ID" \
  --logs ' [{"category": "StorageRead", "enabled": true},
            {"category": "StorageWrite", "enabled": true},
            {"category": "StorageDelete", "enabled": true}] '
```

Activity Log (abonnement) → workspace

```
>_ bash

az monitor diagnostic-settings subscription create --name "activitylog-to-law" \
  --location swedencentral --workspace "$LAW_ID" \
  --logs ' [{"category": "Administrative", "enabled": true},
            {"category": "Security", "enabled": true},
            {"category": "Policy", "enabled": true},
            {"category": "Alert", "enabled": true},
            {"category": "ResourceHealth", "enabled": true}] '
```

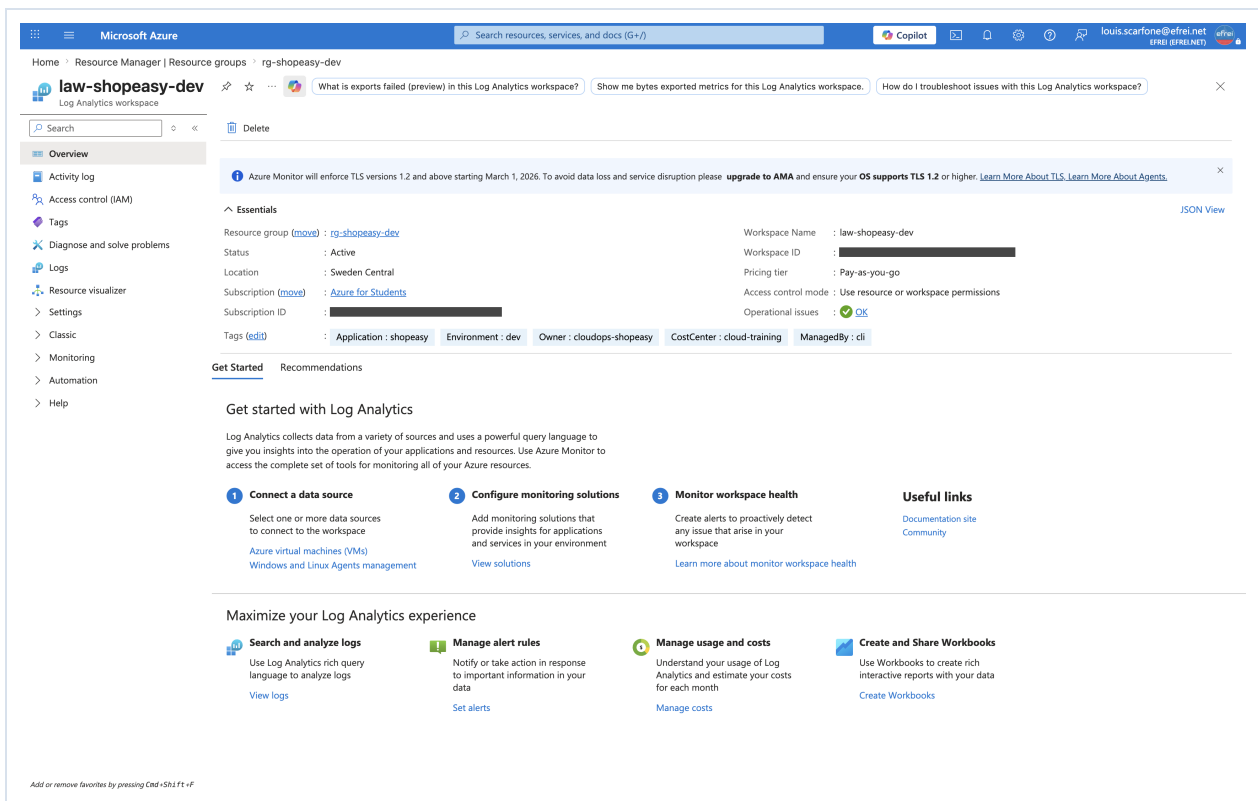
VM — métriques disponibles sans agent

Les **métriques de plateforme** des VM remontent nativement dans Azure Monitor (sans agent ni workspace) : Percentage CPU, CPU Credits Remaining, Network In Total... Les **logs invité** (syslog) et compteurs mémoire/disque nécessitent l'**Azure Monitor Agent** + une **Data Collection Rule** (DCR) vers law-shopeasy-dev — raccordement documenté comme « à connecter ».

2.4 Justification des choix

- **Un workspace centralisé** (law-shopeasy-dev) : corrélér logs et métriques de plusieurs ressources et interroger en KQL depuis un point unique.
- **Activity Log raccordé en priorité** : source d'audit (qui a fait quoi, quand) exploitée à l'Atelier 8 ; Administrative et Security couvrent les changements de configuration et de droits.
- **Storage raccordé** (métrique + logs data-plane) : surveille l'activité (transactions) et les accès aux documents, utile aux coûts et à la sécurité.
- **SKU PerGB2018 / rétention 30 j** : facturation à l'ingestion et rétention courte, adaptées à un environnement de dev.
- **Base SQL et logs invité VM laissés « à connecter »** : honnêteté du périmètre — documentés avec la méthode exacte plutôt que simulés.

2.5 Capture



Espace Log Analytics law-shopeasy-dev (région Sweden Central, SKU PerGB2018, rétention 30 jours). Portal → Log Analytics workspaces → law-shopeasy-dev → Overview.

✓ État après l'atelier

- Ressources **identifiées** (13 ressources ; aucune ressource de monitoring préexistante).
- **Log Analytics Workspace law-shopeasy-dev** créé (swedencentral, PerGB2018, 30 j, Succédé).
- **3 diagnostic settings** opérationnels : Storage (métrique Transaction + logs blob) et Activity Log (Administrative/Security/Policy/Alert/ResourceHealth).

- Métriques VM disponibles nativement; logs invité VM et base SQL documentés «à connecter».
- **Prêt pour l'Atelier 3 — Superviser les machines virtuelles.**

3 Atelier 3 — Superviser les machines virtuelles

🎯 **Objectif** — analyser l'état des machines virtuelles et construire une première vision de supervision.

📦 **Livrable attendu** — un tableau d'analyse des VM avec **au moins deux recommandations** d'exploitation.

3.1 État des VM (inventaire)

>_ bash

```
az vm list -g rg-shopeasy-dev --show-details \
  --query "[].{Nom:name,Etat:powerState,IP_publique:publicIps,IP_privee:privateIps,Taille:hardwareProf|
  ↪ ile.vmSize}" -o table
```

>_ console

Nom	Etat	IP_publique	IP_privee	Taille
vm-shopeasy-dev-web-1	VM running	20.240.255.96	10.20.1.4	Standard_B2ats_v2
vm-shopeasy-dev-web-2	VM running	20.240.47.225	10.20.1.5	Standard_B2ats_v2

Statut de démarrage et provisionnement (az vm get-instance-view) :

>_ bash

```
az vm get-instance-view -g rg-shopeasy-dev -n vm-shopeasy-dev-web-1 \
  --query "instanceView.statuses[?starts_with(code,'PowerState/')] ||
  ↪ starts_with(code,'ProvisioningState/')].{Code:code, Etat:displayStatus}" -o table
```

>_ console

Code	Etat
ProvisioningState/succeeded	Provisioning succeeded
PowerState/running	VM running

Les deux VM sont **running**, provisionnées avec succès, en Standard_B2ats_v2 (Ubuntu + Nginx). Aucune erreur dans l'*instance view*.

3.2 Métriques observées (Azure Monitor)

Lecture des métriques demandées via `az monitor metrics list` (fenêtre des 30–60 dernières min) :

```
>_ bash

VM1_ID=$(az vm show -g rg-shopeasy-dev -n vm-shopeasy-dev-web-1 --query id -o tsv)
az monitor metrics list --resource "$VM1_ID" --metric "Percentage CPU" \
  --interval PT5M --aggregation Average Maximum -o table
```

Métrique demandée	Métrique Azure	VM web-1	VM web-2	Lecture
Pourcentage CPU	Percentage CPU	pic 19 % au boot → ≈0,3 % moy. (1,1 % max) au repos	idem	VM au repos (page statique, pas de trafic réel).
Réseau entr./sort.	Network In/Out Total	242 Ko / 404 Ko	229 Ko / 327 Ko	Trafic faible (sondes + administration).
Disque lu/écrit	Disk Read/Write Bytes	2,40 Mo / 2,16 Mo	2,55 Mo / 2,78 Mo	Activité de boot (cloud-init), puis quasi nulle.
Disponibilité VM	VmAvailabilityMetric	1.0 (saine)	1.0 (saine)	La VM est disponible au niveau plateforme .
Erreurs éventuelles	instance view	aucune (succeeded)	aucune	Pas d'erreur d'infra ; erreurs applicatives non visibles ici.
Statut de démarrage	Power/ProvisioningState	running / succeeded	running / succeeded	Démarrage nominal.

Métriques complémentaires utiles, propres au contexte :

```
>_ console

CPU Credits Remaining : 63,14 (burstable B2ats_v2 : reserve de credits saine)
Available Memory Bytes : ~528 Mo (sur 1 Gio : ~la moitié libre au repos)
```

⚠ VM burstable B2ats_v2

La VM Standard_B2ats_v2 est **burstable** (1 Gio de RAM, 2 vCPU) : les **crédits CPU** et la **mémoire disponible** sont des indicateurs déterminants (un CPU élevé prolongé épuise les crédits → bridage ; 1 Gio de RAM est la ressource la plus contrainte).

3.3 Questions d'analyse

1. La VM est-elle correctement dimensionnée ?

Pour l'usage actuel (page Nginx statique, sans trafic réel), elle est **largement dimensionnée côté**

CPU ($\approx 0,3$ % au repos, 63 crédits en réserve) — une taille burstable de série B est adaptée à un environnement de dev. Le point de vigilance est la **mémoire** : B2ats_v2 n'offre que **1 Gio**, dont $\approx$ la moitié est déjà consommée au repos. Sous charge réelle, la **RAM serait le facteur limitant** avant le CPU. Verdict : bien dimensionnée pour le dev/test, mais à re-dimensionner (RAM) avant toute mise en charge de production. (*Rappel : B1s est indisponible sur Azure for Students, B2ats_v2 est l'alternative recommandée.*)

2. Les métriques disponibles suffisent-elles à diagnostiquer un incident applicatif ?

Non. Les métriques de plateforme (CPU, réseau, disque, disponibilité, mémoire) décrivent l'état de l'**infrastructure**, pas celui de l'**application**. Un incident applicatif — Nginx qui renvoie des 500, une requête lente, une erreur de configuration — peut survenir alors que la VM est **parfaitement saine au niveau infra** (VmAvailabilityMetric = 1, CPU bas). Ces métriques disent *si la machine tourne, pas si le service rend correctement le service*.

3. Quelles métriques manquent pour une supervision applicative complète ?

- **Codes de statut HTTP** et **taux d'erreurs** (5xx/4xx) issus des logs Nginx ;
- **Temps de réponse / latence** (P95) ;
- **Débit applicatif** (requêtes/s) et **connexions actives** Nginx ;
- **Logs applicatifs** (erreurs, exceptions) centralisés dans Log Analytics ;
- **Disponibilité synthétique** vue utilisateur (cf. question 4).

Ces signaux nécessitent l'**Azure Monitor Agent** (syslog + logs Nginx → law-shopeasy-dev) et/ou **Application Insights**.

4. Que faudrait-il ajouter pour connaître la disponibilité réelle vue par un utilisateur ?

VmAvailabilityMetric = 1 indique seulement que la VM tourne **au niveau plateforme**, pas que le site répond. Pour mesurer la disponibilité **réellement perçue**, il faut une **sonde synthétique** : un test externe qui interroge périodiquement le site via l'**IP publique du Load Balancer** (<http://4.223.84.214>) et vérifie le **code 200 + le contenu + le temps de réponse**. Dans Azure, c'est un **URL ping test** (Application Insights / Log Analytics) ou le suivi du **Health Probe Status** du Load Balancer. Cette sonde mesure la chaîne complète (DNS → LB → VM → Nginx → réponse), c'est-à-dire l'expérience réelle de l'utilisateur.

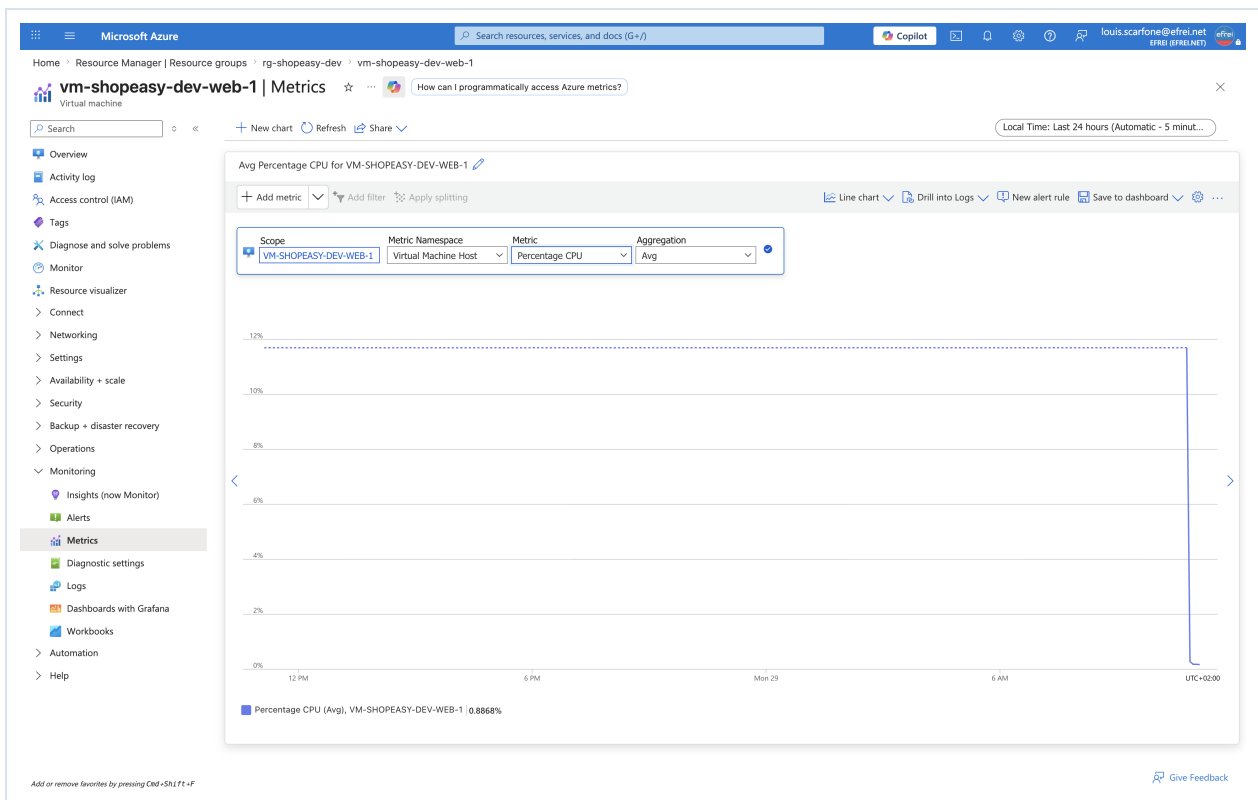
3.4 Tableau d'analyse des VM

VM	État	Risque observé	Action proposée
vm-...-web-1	running, dispo 1.0, CPU $\approx 0,3$ %, crédits CPU 63, mémoire ≈ 528 Mo / 1 Gio	RAM contrainte (1 Gio) → saturation possible sous charge ; aucune supervision applicative ; pas de sonde de disponibilité utilisateur	Surveiller mémoire + crédits CPU (alerte, Atelier 4) ; raccorder syslog + logs Nginx (AMA + DCR) ; ajouter une sonde de disponibilité synthétique
vm-...-web-2	running, dispo 1.0, profil identique	Idem web-1 ; désallouée par défaut en dev (HA), elle ne sert que les tests de répartition	Mêmes actions ; vérifier son redémarrage avant les tests de charge

Recommandations d'exploitation

1. **Mettre en place une supervision applicative** : les métriques d'infrastructure ne suffisent pas (Q2). Raccorder les **logs Nginx + codes HTTP** à law-shopeasy-dev (Azure Monitor Agent + DCR).
2. **Ajouter une sonde de disponibilité synthétique** (URL ping test sur l'IP du Load Balancer) pour mesurer la disponibilité réelle vue par l'utilisateur.
3. **Surveiller mémoire et crédits CPU** (spécifiques au burstable 1 Gio) et matérialiser ces seuils en alertes (Atelier 4).

3.5 Capture



Graphique de la métrique *Percentage CPU* de la VM web (au repos). Portal → Virtual machines → vm-shopeasy-dev-web-1 → Monitoring → Metrics.

✓ État après l'atelier

- État des 2 VM relevé (running, provisioning succeeded, disponibilité 1.0).
- Métriques observées dans Azure Monitor : CPU ($\approx 0,3$ % au repos), réseau, disque, disponibilité, mémoire, crédits CPU.
- 4 questions d'analyse traitées (dimensionnement, limites des métriques d'infra, métriques applicatives manquantes, disponibilité utilisateur).
- Tableau d'analyse des VM + **3 recommandations** d'exploitation.
- **Prêt pour l'Atelier 4 — Créer des alertes opérationnelles.**

4 Atelier 4 — Créer des alertes opérationnelles

- 🎯 **Objectif** — configurer des alertes permettant de détecter rapidement un incident.
- 📄 **Livrable attendu** — une **fiche d'alerte** avec nom, ressource cible, seuil, criticité, destinataire et procédure de réaction.

4.1 Alertes retenues

Parmi les alertes proposées par l'énoncé, **deux sont configurées réellement** dans cet atelier ; les autres sont rattachées aux ateliers dédiés.

Alerte	Seuil	Criticité	Action attendue	Statut
CPU élevé VM web	> 70 % (moy. 5 min)	Moyenne	Vérifier la charge, les logs et le dimensionnement	✅ Config.
VM indisponible	VmAvailabilityMetric < 1	Haute	Redémarrage, escalade, analyse d'incident	✅ Config.
Budget dépassé	> 80 % du budget	Moyenne	Analyse des coûts, suppression des ressources inutiles	→ Atelier 6
Activité critique (Activity Log)	modification de droits / NSG	Moyenne	Vérifier l'auteur et la légitimité du changement	→ Atelier 8

4.2 Action Group — qui est notifié et comment

Un **Action Group** définit les destinataires d'une alerte. Ici, un récepteur **e-mail** vers l'équipe d'exploitation (en contexte réel : webhook, ITSM ou canal d'exploitation en complément).

>_ bash

```
az monitor action-group create \
  --resource-group rg-shopeasy-dev --name ag-shopeasy-ops --short-name shopops \
  --action email EquipeOps louis.scarfone@efrei.net
```

>_ json

```
{
  "Nom": "ag-shopeasy-ops",
  "ShortName": "shopops",
  "Destinataire": "EquipeOps",
  "Email": "louis.scarfone@efrei.net",
  "Etat": "Enabled"
}
```

4.3 Création des alertes (Azure CLI)

>_ bash

```
AG_ID=$(az monitor action-group show -g rg-shopeasy-dev -n ag-shopeasy-ops --query id -o tsv)
VM1_ID=$(az vm show -g rg-shopeasy-dev -n vm-shopeasy-dev-web-1 --query id -o tsv)

# Alerte 1 - CPU moyen > 70% (Moyenne / Sev2)
az monitor metrics alert create \
  --name "alert-cpu-high-vm-shopeasy-dev-web-1" --resource-group rg-shopeasy-dev --scopes "$VM1_ID" \
  --condition "avg Percentage CPU > 70" \
  --window-size 5m --evaluation-frequency 1m \
  --severity 2 --action "$AG_ID" \
  --description "CPU moyen de la VM web superieur a 70% pendant 5 min"

# Alerte 2 - VM indisponible (Haute / Sev1)
az monitor metrics alert create \
  --name "alert-vm-unavailable-vm-shopeasy-dev-web-1" --resource-group rg-shopeasy-dev --scopes
  ↪ "$VM1_ID" \
  --condition "avg VmAvailabilityMetric < 1" \
  --window-size 5m --evaluation-frequency 1m \
  --severity 1 --action "$AG_ID" \
  --description "Disponibilite de la VM web inferieure a 1 (VM indisponible)"
```

Vérification (az monitor metrics alert list):

>_ console

Nom	Active	Sev	Condition
-----	-----	-----	-----
alert-cpu-high-vm-shopeasy-dev-web-1	True	2	Percentage CPU
alert-vm-unavailable-vm-shopeasy-dev-web-1	True	1	VmAvailabilityMetric

💡 Choix du seuil CPU

Seuil CPU à 70 % (et non 80 %) : aligné sur l'exemple de l'énoncé. Le seuil se cale entre 70 et 80 % selon la baseline ($\approx 0,3$ % au repos, Atelier 3) — assez haut pour ignorer les pics normaux, assez bas pour détecter une saturation soutenue avant dégradation. **Sévérités** : Sev 2 = *Warning* (Moyenne), Sev 1 = *Error* (Haute).

4.4 Fiches d'alerte (livrable)

Fiche 1 — CPU élevé VM web

Champ	Valeur
Nom	alert-cpu-high-vm-shopeasy-dev-web-1
Ressource cible	VM vm-shopeasy-dev-web-1 (Standard_B2ats_v2)
Seuil	CPU moyen > 70 %, fenêtre 5 min, évaluation 1 min
Criticité	Moyenne (Sev 2)
Destinataire	Action Group ag-shopeasy-ops → e-mail Equipe0ps
Procédure de réaction	1) Vérifier le trafic et les crédits CPU (burstable). 2) Consulter les logs Nginx (pic de requêtes ? boucle ?). 3) Si charge légitime et soutenue → redimensionner ou ajouter une instance. 4) Si anormale → identifier le processus, corriger. 5) Journaliser l'incident.

Fiche 2 — VM indisponible

Champ	Valeur
Nom	alert-vm-unavailable-vm-shopeasy-dev-web-1
Ressource cible	VM vm-shopeasy-dev-web-1
Seuil	VmAvailabilityMetric < 1, fenêtre 5 min, évaluation 1 min
Criticité	Haute (Sev 1)
Destinataire	Action Group ag-shopeasy-ops → e-mail Equipe0ps
Procédure de réaction	1) Vérifier l'état dans le portail (PowerState, <i>boot diagnostics</i>). 2) Tenter un redémarrage (az vm restart). 3) Vérifier que le Load Balancer a retiré la VM du pool (continuité de service sur l'autre VM). 4) Si échec → escalader et analyser (incident matériel / OS). 5) Post-mortem.

4.5 Questions d'analyse

1. Quel risque y a-t-il à définir des seuils trop bas ?

La **fatigue d'alerte** (*alert fatigue*) : l'alerte se déclenche sur des variations normales (faux positifs) et **noie** les équipes sous des notifications non prioritaires. À force, elles **ignorent** les alertes et **ratent les vrais incidents**. Exemple : CPU > 40 % sur 1 min se déclencherait à chaque déploiement, sans qu'aucune action ne soit requise.

2. Quel risque y a-t-il à définir des seuils trop hauts ?

La **détection tardive** : on n'est prévenu qu'une fois le service **déjà dégradé ou en panne**, donc trop tard pour agir préventivement. Exemple : CPU > 98 % sur 30 min ignore une saturation à 85 % qui **ralentit déjà** les utilisateurs. Le seuil trop haut transforme une alerte préventive en simple constat

d'incident.

3. Pourquoi faut-il documenter une action attendue pour chaque alerte ?

Parce qu'une alerte doit être **actionnable**. Sans **procédure** (runbook : quoi vérifier, qui contacter, quelle action), le destinataire reçoit un signal **sans savoir quoi en faire** → perte de temps, mauvaise réaction, ou alerte ignorée. La procédure rend l'alerte exploitable, **réduit le MTTR** et garantit une réponse cohérente. C'est ce qui distingue une **alerte** d'un simple **bruit**.

4. Comment éviter la fatigue d'alerte ?

- **Distinguer les criticités** : critique (action immédiate) / avertissement (analyse) / information (reporting en dashboard, pas en alerte).
- **Calibrer les seuils** sur la **baseline** réelle + une **fenêtre de lissage** (5 min).
- **N'alerter que sur l'actionnable** (règle-filtre : « une personne doit-elle vraiment agir ? ») ; le reste va au tableau de bord.
- **Regrouper** les notifications via les **Action Groups** et **supprimer les alertes redondantes**.
- **Réviser régulièrement** les règles (supprimer celles qui ne déclenchent jamais ou trop souvent).

4.6 Captures

Microsoft Azure

Home > Monitor | Alerts

Alert rules

+ Create | Columns | Refresh | Export to CSV | Open query | Delete | Enable | Disable

New: Let Observability Agent reason over your alerts to automatically correlate alert noise for faster investigations. Request preview access

Search

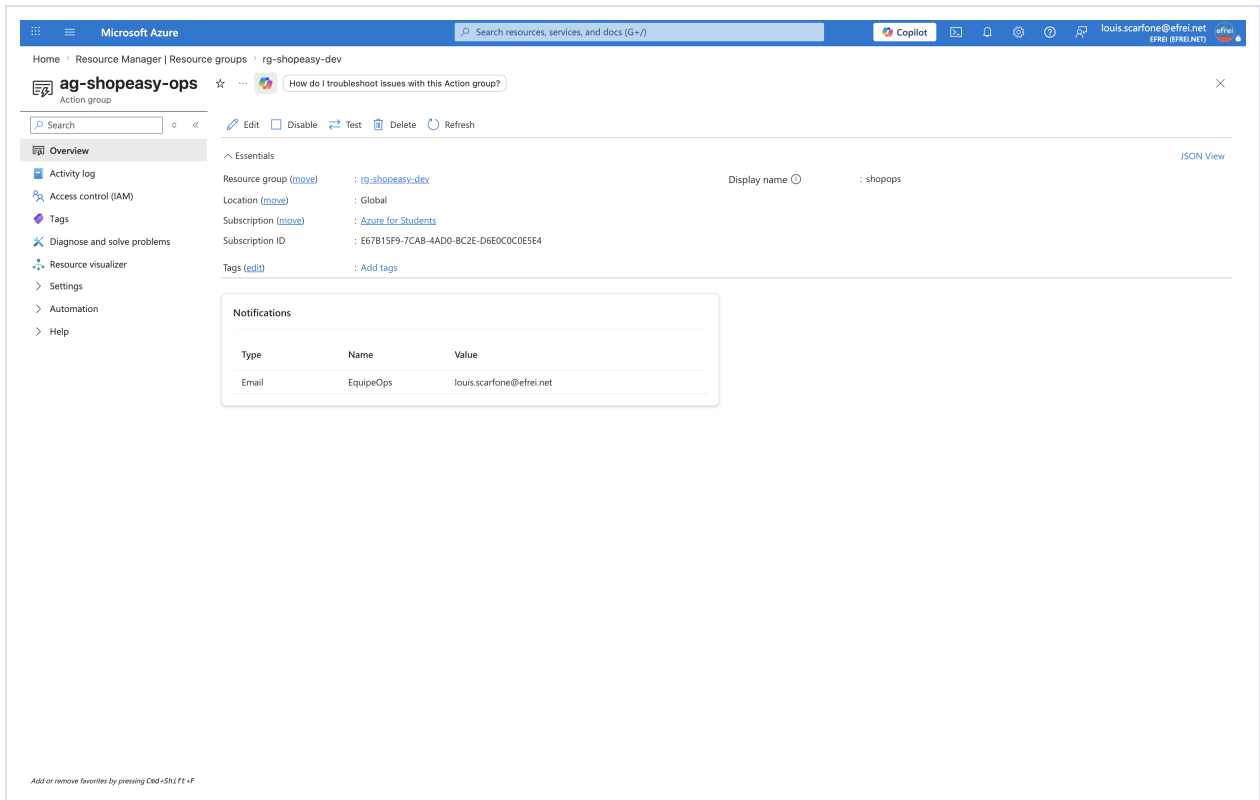
Subscription: Azure for Students | Target scope: all | Target resource type: all | Signal type: all | Severity: all | Status: Enabled | Add tag filter | No grouping

Name ↑↓	Condition	Severity ↑↓	Target scope	Target resource type	Signal type ↑↓	Status ↑↓
☐ alert-cpu-high-vm-shopeasy-dev-we...	Percentage CPU > 70	2 - Warning	vm-shopeasy-dev-web-1	Virtual machine	Metrics	Enabled
☐ alert-vm-unavailable-vm-shopeasy-dev	VmAvailabilityMetric < 1	1 - Error	vm-shopeasy-dev-web-1	Virtual machine	Metrics	Enabled

Showing 1 - 2 of 2 results.

Give feedback

Les deux règles d'alerte actives (alert-cpu-high et alert-vm-unavailable), état Enabled. Portal → Monitor → Alerts → Alert rules.



Action Group *ag-shopeasy-ops* et son récepteur e-mail *EquipeOps*. Portal → Monitor → Alerts → Action groups.

✓ État après l'atelier

- **Action Group *ag-shopeasy-ops*** créé (récepteur e-mail *EquipeOps*, Enabled).
- **2 alertes opérationnelles actives** : CPU > 70 % (Moyenne) et VM indisponible (Haute), rattachées à l'Action Group.
- **2 fiches d'alerte** complètes (nom, ressource, seuil, criticité, destinataire, procédure).
- 4 questions d'analyse traitées (seuils trop bas/hauts, action documentée, fatigue d'alerte).
- **Prêt pour l'Atelier 5 — Construire un tableau de bord d'exploitation.**

5 Atelier 5 — Construire un tableau de bord d'exploitation

- 🎯 **Objectif** — créer une vue synthétique permettant à une équipe SI de suivre l'état de l'application ShopEasy.
- 📦 **Livrable attendu** — capture du dashboard **ou** maquette détaillée, avec justification de chaque tuile.

5.1 Approche retenue — un dashboard Azure réel

Le tableau de bord a été **réellement créé dans Azure** via `az portal dashboard create` (ressource `Microsoft.Portal/dashboards` nommée `ShopEasy-Exploitation`) — capture au §4. Il regroupe **9 tuiles de métriques réelles** (graphes Azure Monitor sur les VM et le Storage), **sans tuile factice ni texte de remplissage**.

Le dashboard couvre les **quatre axes de métriques** du contenu minimal de l'énoncé (état des VM, CPU, trafic réseau, stockage). Les autres items — **coûts, alertes, journaux** — ne sont **pas des graphes de métriques** mais des **lames Azure dédiées** (Cost Management, Monitor Alerts, Activity Log), traitées dans leurs ateliers respectifs et épinglables au dashboard. La **base de données** n'est pas déployée (cible TP1, hors périmètre Terraform du TP2).

5.2 Les 9 tuiles du dashboard

#	Tuile (métrique Azure)	Ressource	Donnée réelle	Décision facilitée
1	Disponibilité des VM (VmAvailabilityMetric)	web-1 + web-2	1.0 (saines)	Détecter une indisponibilité plateforme
2	CPU des VM (Percentage CPU)	web-1 + web-2	≈0,3 % au repos	Identifier une surcharge
3	Réseau entrant (Network In Total)	web-1 + web-2	242 / 229 Ko	Détecter un pic de trafic / une attaque
4	Réseau sortant (Network Out Total)	web-1 + web-2	404 / 327 Ko	Détecter une exfiltration / une chute
5	Stockage — capacité (Used capacity)	Storage	volume faible	Surveiller la croissance du stockage
6	Stockage — transactions (Transactions)	Storage	activité blob	Surveiller l' activité et les coûts
7	Crédits CPU (CPU Credits Remaining)	web-1 + web-2	63 (réserve saine)	Anticiper le bridage (burstable)
8	Mémoire disponible (Available Memory Bytes)	web-1 + web-2	≈528 Mo / 1 Gio	Anticiper une saturation mémoire
9	Disque lu/écrit (Disk Read/Write Bytes)	web-1	2,40 / 2,16 Mo	Détecter une saturation I/O

Les tuiles 1 à 6 couvrent les axes métriques de l'énoncé ; les tuiles 7 à 9 ajoutent les indicateurs **propres au burstable B2ats_v2** (crédits CPU, mémoire) et les I/O disque — les plus contraints sur cette taille.

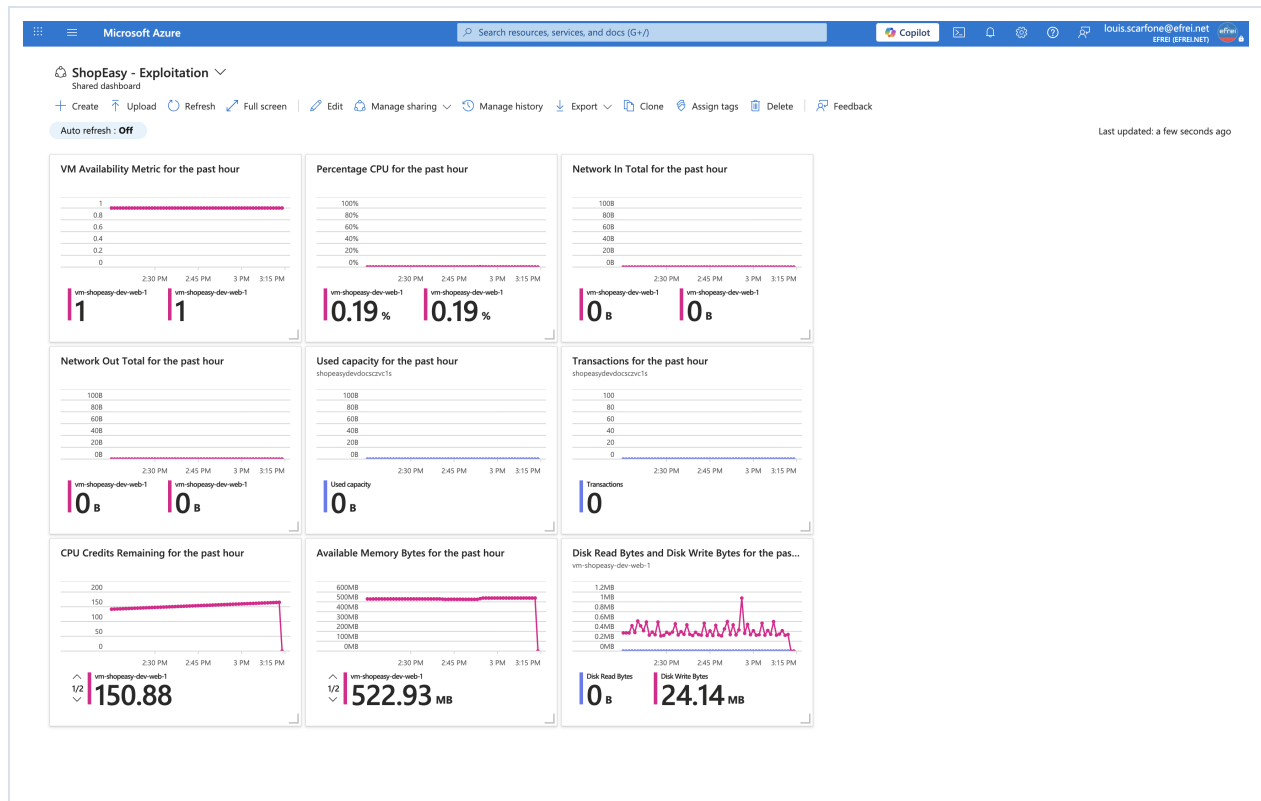
5.3 Couverture du contenu minimal de l'énoncé

Item attendu (énoncé)	Sur le dashboard ?	Source / traitement
État des VM	✓ Tuile 1	VmAvailabilityMetric (graphe)
CPU des VM	✓ Tuile 2	Percentage CPU (graphe)
Trafic réseau	✓ Tuiles 3-4	Network In/Out Total (graphes)
Stockage consommé	✓ Tuiles 5-6	Used capacity + Transactions (graphes)
État de la base de données	→ Hors dashboard	Base SQL non déployée (cible TP1, hors Terraform TP2)
Coûts / Budget	→ Lame dédiée	Cost Management → Atelier 6 (épinglable)
Alertes récentes	→ Lame dédiée	Azure Monitor → Alerts → Atelier 4
Lien journaux / Activity Log	→ Lame dédiée	Activity Log + law-shopeasy-dev (KQL) → Atelier 8

💡 Cockpit d'exploitation

Le dashboard est la **vue de supervision temps réel** (métriques). Le cockpit complet s'appuie en plus sur les **lames natives** Cost Management, Monitor Alerts et Activity Log — chacune approfondie dans son atelier et **épinglable** au même dashboard si besoin.

5.4 Capture — dashboard Azure réel



Dashboard ShopEasy-Exploitation : 9 tuiles de métriques (dispo VM, CPU, réseau in/out, stockage capacité/transactions, crédits CPU, mémoire, disque). Portal → Dashboard → Shared dashboards → ShopEasy - Exploitation.

5.5 Pourquoi ce tableau de bord

Un tableau de bord utile ne se limite pas à empiler des courbes : il répond aux **questions de pilotage**. Ici, les 9 tuiles permettent de voir d'un coup d'œil **si le service tourne** (disponibilité), **s'il est saturé** (CPU, crédits CPU, mémoire, disque), et **comment il consomme** (réseau, stockage) — les signaux les plus utiles pour une VM web burstable. La dépense, les incidents et la traçabilité complètent le pilotage via leurs lames dédiées, gardant le dashboard **lisible et 100 % métriques**.

✓ État après l'atelier

- **Dashboard Azure réel** ShopEasy-Exploitation créé (az portal dashboard create) : **9 tuiles de métriques** (VM + Storage), **aucune tuile markdown**.
- Les 4 axes métriques de l'énoncé (état VM, CPU, réseau, stockage) sont des **tuiles réelles**; coûts / alertes / journaux sont **mappés à leurs lames** (Ateliers 6 / 4 / 8); base SQL non déployée.
- Tableau des 9 tuiles + couverture du contenu minimal de l'énoncé.
- **Prêt pour l'Atelier 6 — Analyse FinOps.**

6 Atelier 6 — Analyse FinOps

🎯 **Objectif** — comprendre les coûts de l’environnement et proposer des optimisations réalistes.

📦 **Livrable attendu** — une analyse FinOps structurée avec **au moins cinq constats et cinq actions correctives**.

6.1 Analyse des coûts

Méthode. Les données de **coût réel** (Cost Management) n’apparaissent qu’après 24–48 h sur un abonnement récent : `az consumption usage list` remonte déjà les **compteurs** facturés (IP Standard IPv4, disques Standard HDD S4 LRS) mais leur `PretaxCost` est encore `None`. Les montants ci-dessous sont calculés à partir des **prix réels** de l’API **Azure Retail Prices** (région `swedencentral`, USD, base 730 h/mois) — prix VM confirmé en direct : **Standard_B2ats_v2 = 0,00972 \$/h**.

Poste	Calcul	Coût \$/mois	Part
Load Balancer Standard	forfait règles + data	≈ 18,25	~39 %
Compute — 2 VM B2ats_v2	$2 \times 0,00972 \times 730$	≈ 14,19	~30 %
3 IP publiques Standard	$3 \times 0,005 \times 730$	≈ 10,95	~23 %
2 disques OS Standard HDD S4 LRS	~1,30 chacun	≈ 2,60	~6 %
Storage Account LRS	usage faible	< 1	~2 %
Total		≈ 47 \$/mois	100 %

Tout l’environnement tient dans **un seul groupe** `rg-shopeasy-dev` (≈ 47 \$/mois). Les **3 postes les plus coûteux** (Load Balancer + compute + IP) représentent ~92 % du coût ; le **Load Balancer** et les **IP publiques** facturent 24/7, **indépendamment du trafic** — seul le **compute** est élastique (réductible par désallocation).

>_ bash

```
az resource list -g rg-shopeasy-dev --query "length([?tags.Application==null])" -o tsv # -> 14
az disk list -g rg-shopeasy-dev --query "length([?managedBy==null])" -o tsv # -> 0
az network public-ip list -g rg-shopeasy-dev --query "length([?ipConfiguration==null])" -o tsv # -> 0
```

- 14 ressources sans tag **Application** après normalisation du RG + 2 VM → coût **non imputable**.
- 0 disque orphelin, 0 IP non associée : environnement **propre**, aucun coût « invisible ».
- Coût prévisionnel : ≈ 47 \$/mois en 24/7 (≈ 30 \$ avec désallocation des VM, ≈ 0 si destruction de l’environnement).
- **Recommandations Advisor (coût)** : aucune sur cet environnement récent (Advisor a besoin d’un historique d’usage).

6.2 Politique de tags de gouvernance

Politique de tags **minimale** proposée pour ShopEasy :

Tag	Exemple	Utilité
Application	shopeasy	Regrouper les coûts par application
Environment	dev / test / prod	Distinguer les environnements
Owner	cloudops-shopeasy	Identifier le responsable
CostCenter	cloud-training	Affecter les coûts à un centre de coût
Criticality	low / medium / high	Prioriser supervision et sécurité

Application au groupe de ressources et aux VM :

```
>_ bash

# Groupe de ressources
az group update -n rg-shopeasy-dev --tags Application=shopeasy Environment=dev \
  Owner=cloudops-shopeasy CostCenter=cloud-training Criticality=high

# Chaque VM (az resource tag --ids)
az resource tag --ids "$VM_ID" --tags Application=shopeasy Environment=dev \
  Owner=cloudops-shopeasy CostCenter=cloud-training Criticality=high Role=web
```

Le nombre de ressources sans tag Application est passé de **16 à 14** (RG + 2 VM normalisés). La généralisation aux 14 restantes doit passer par **Azure Policy** (audit ou refus à la création d'une ressource sans Application/Owner).

6.3 Tableau d'optimisation FinOps

#	Constat	Risque financier	Priorité	Action proposée
1	VM allumées 24/7 (inutilisées en dev)	Dépense compute inutile (~14 \$/mois)	Haute	Désallouer hors usage (az vm deallocate); détruire l'environnement entre les séances (terraform destroy)
2	3 IP publiques + Load Balancer facturés à vide	~29 \$/mois indépendants du trafic	Haute	Supprimer les IP directes des VM (→ Azure Bastion); ne garder le LB que si nécessaire
3	14 ressources sans tag Application	Coût non imputable	Moyenne	Généraliser la politique de tags via Azure Policy
4	Aucun budget actif	Dérive non détectée	Moyenne	Créer un budget 50 \$/mois (Cost Management) + alertes 80 % / 100 %
5	Disque non attaché (orphelin)	Coût oublié	Basse	Aucun actuellement (0 orphelin); automatiser le contrôle (az disk list / az network public-ip list)
6	VM potentiellement surdimensionnée	Sur-paiement	Basse	B2ats_v2 déjà minimale; surveiller CPU Credits avant tout downsize

6.4 Budget mensuel (50 \$) — design et mise en œuvre

Budget visé : 50 \$/mois, avec deux seuils d'alerte : 80 % (40 \$) → vigilance, et 100 % (50 \$) → dépassement, action requise.

```
>_ bash
```

```
az consumption budget create --budget-name budget-shopeasy-dev \
--amount 50 --category Cost --time-grain Monthly \
--start-date 2026-06-01 --end-date 2027-06-01 --resource-group rg-shopeasy-dev
```

⚠ Limite rencontrée

az consumption budget create (commande **en préview**) renvoie 400 – Invalid budget configuration, please use filter interface sur cet abonnement *Azure for Students*. En pratique, le budget se crée de façon fiable via **Cost Management** → **Budgets** → **Add** (portail) ou l'API REST 2019-05-01-preview. Le design (montant, grain, seuils 80/100 %) reste celui ci-dessus.

6.5 Questions d'analyse

1. Pourquoi le cloud peut-il coûter plus cher que prévu ?

Parce que la dépense apparaît **au fil de la consommation** (OPEX) et non à l'achat (CAPEX) : elle varie avec l'activité, les **erreurs de configuration** et les **ressources oubliées**. Plusieurs pièges : ressources **facturées à vide** (Load Balancer, IP publiques même sans trafic), **surdimensionnement**, environnements de test **laissés allumés**, stockage et versions qui **s'accumulent**, et surtout **absence de tags/budget** qui prive de visibilité. On découvre alors la dérive **sur la facture**, trop tard.

2. Quelles ressources doivent être arrêtées hors période d'utilisation ?

Les **VM de développement** : `az vm deallocate` ramène leur coût compute à 0 (≈ 14 \$/mois économisés). Le **Load Balancer** et les **IP publiques**, facturés à vide, peuvent être supprimés hors usage (recréables par Terraform). Le levier maximal reste de **détruire l'environnement entier** (`terraform destroy`) entre les séances $\rightarrow$ coût ≈ 0 , recréable à l'identique par `terraform apply`.

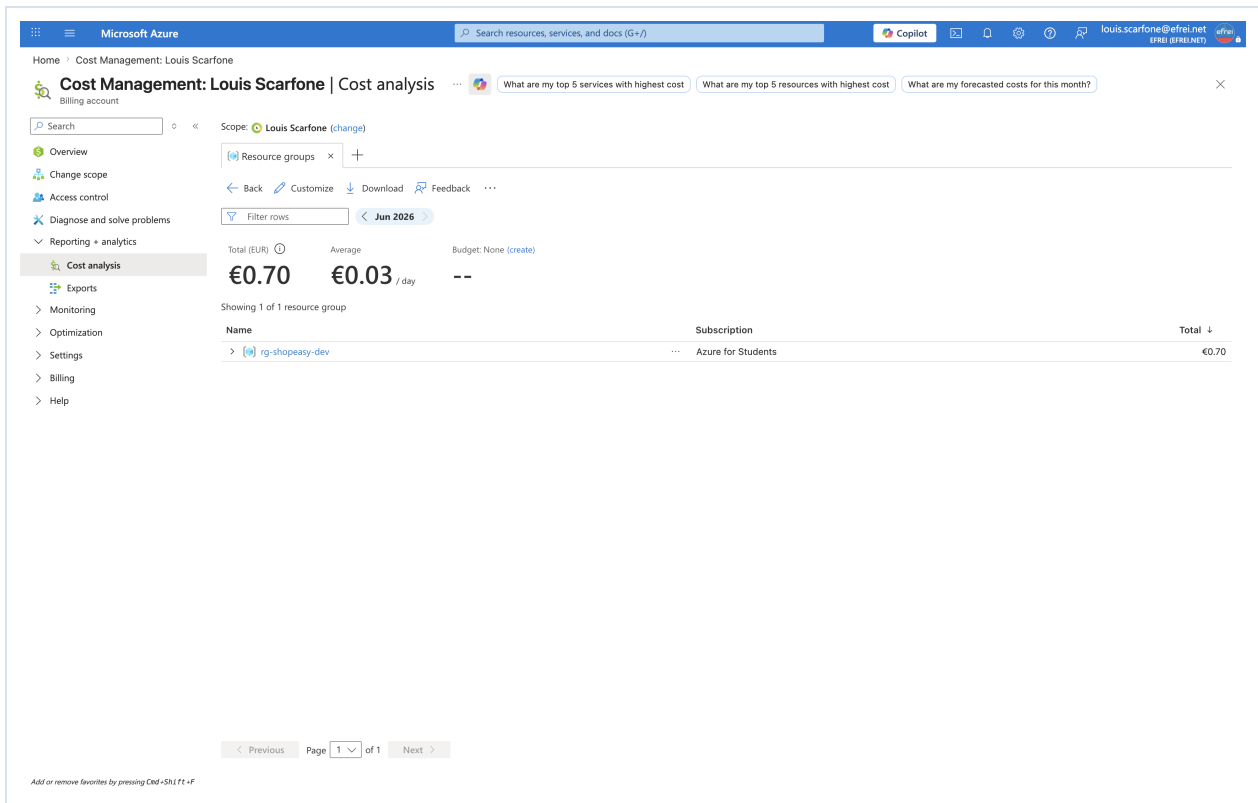
3. Pourquoi les tags sont-ils indispensables pour une DSI ?

Ils permettent d'**imputer** les coûts (par application, environnement, **centre de coût**), d'**identifier le responsable** (Owner), de **prioriser** (Criticality) et d'**automatiser** la gouvernance (Azure Policy, arrêt automatique des ressources dev). Sans tags, la DSI ne peut ni répondre à « combien coûte ShopEasy en dev ? », ni imputer une dépense, ni piloter — la facture devient un bloc opaque.

4. Quelle différence entre réduction de coût et optimisation de valeur ?

Réduire = baisser la dépense, parfois **au détriment du service** (supprimer, sous-dimensionner aveuglément). **Optimiser** = obtenir le **meilleur rapport valeur/coût** : bon dimensionnement, suppression du **gaspillage** (ressources oubliées, surdimensionnées, facturées à vide), choix du bon niveau de service — **sans dégrader la valeur métier**. La cible FinOps est l'**optimisation**, pas la réduction aveugle.

6.6 Capture



Analyse des coûts du groupe `rg-shopeasy-dev` dans Cost Management. Portal → Cost Management → Cost analysis (les montants réels n'apparaissent qu'après 24–48 h).

✓ État après l'atelier

- Coûts analysés (prix réels Azure Retail Prices) : **≈ 47 \$/mois en 24/7**, dont **~92 %** sur Load Balancer + compute + IP ; environnement **propre** (0 orphelin).
- Politique de tags minimale **proposée et appliquée** (RG + 2 VM, avec Criticality) ; 14 ressources restantes à généraliser via Azure Policy.
- **Tableau d'optimisation FinOps** : 6 constats / risque / priorité / action (≥ 5 demandés).
- Budget 50 \$/mois conçu (seuils 80/100 %) ; création CLI bloquée (API préview) → à créer via Cost Management.
- **Prêt pour l'Atelier 7 — Revue de sécurité Azure.**

7 Atelier 7 — Revue de sécurité Azure

🎯 **Objectif** — identifier les principaux risques de sécurité de l'environnement et proposer un plan d'amélioration.

📦 **Livrable attendu** — une matrice de risques sécurité avec **au moins cinq risques**, leur criticité et les mesures correctives proposées.

7.1 Points de contrôle

Point de contrôle	Constat réel	Verdict
Rôles attribués (RBAC)	1 compte Owner (hérité de l'abonnement)	⚠️ droits larges
Utilisateurs à droits élevés	<code>louis.scarfone@efrei.net</code> = Owner	⚠️
Ressources exposées publiquement	3 IP publiques (1 Load Balancer + 2 VM)	⚠️ 2 IP de VM inutiles
Règles NSG trop ouvertes	HTTP 80 (Internet), SSH 22 (<IP_ADMIN>/32)	✅ aucun 0.0.0.0/0 sensible
Accès SSH / RDP depuis Internet	SSH restreint à l'IP admin ; pas de RDP	✅
Chiffrement du stockage	SSE activé, TLS 1.2, HTTPS-only	✅
Accès public du Storage	<code>allowBlobPublicAccess = True</code>	⚠️ à désactiver
Logs d'activité disponibles	<code>activitylog-to-law</code> → <code>law-shopeasy-dev</code>	✅ disponibles
Recommandations Defender / Advisor	Defender non activé, MAJ non vérifiées...	⚠️ (cf. §4)

7.2 Contrôle RBAC

>_ bash		
<pre>az role assignment list --resource-group rg-shopeasy-dev --include-inherited \ --query "[].{Principal:principalName, Role:roleDefinitionName, Type:principalType}" -o table</pre>		
>_ console		
Principal	Role	Type
-----	-----	-----
<code>louis.scarfone@efrei.net</code>	<code>Owner</code>	User
<code>louis.scarfone@efrei.net</code>	<code>Owner</code>	User

Le compte d'administration détient le rôle **Owner** (hérité de l'abonnement). Aucune attribution directe au niveau du RG. Pour une **équipe**, c'est un privilège trop large : il faut appliquer le **moindre privilège** (Reader/Contributor selon le besoin) et **MFA**. (*Advisor signale aussi, pour la résilience, qu'un second owner « break-glass » serait souhaitable — complémentaire au moindre privilège.*)

7.3 Contrôle NSG

>_ bash

```
az network nsg rule list -g rg-shopeasy-dev --nsg-name nsg-shopeasy-dev-web \
--query "sort_by([].{Nom:name,Prio:priority,Sens:direction,Acces:access,Port:destinationPortRange,Source:sourceAddressPrefix}, &Prio)" -o table
```

>_ console

Nom	Prio	Sens	Acces	Port	Source
Allow-HTTP	100	Inbound	Allow	80	Internet
Allow-SSH-Admin	110	Inbound	Allow	22	<IP_ADMIN>/32

- **HTTP (80)** ouvert depuis Internet : nécessaire pour exposer le site (trafic en clair → HTTPS en production).
- **SSH (22)** restreint à l'**IP de l'administrateur (/32)**, **jamais 0.0.0.0/0** ; la règle par défaut DenyAllInBound bloque le reste. **Aucune règle dangereuse** (pas de RDP, pas de port d'administration ouvert à Internet).

7.4 Exposition, chiffrement et recommandations

Ressources exposées : 3 IP publiques — pip-shopeasy-dev-lb (4.223.84.214, point d'entrée légitime) et **2 IP directes sur les VM** (20.240.255.96, 20.240.47.225) qui élargissent inutilement la surface d'attaque (administration possible via Bastion à la place).

Chiffrement du Storage :

>_ console

Nom	ChiffrementRepos	TLS	HttpsOnly	AccesPublicBlob
shopeasydevdocsczvc1s	True	TLS1_2	True	True

Le chiffrement au repos (SSE), TLS 1.2 et HTTPS-only sont **corrects**, mais **AllowBlobPublicAccess = True** (défaut Terraform) : le compte **autoriserait** un conteneur public. À **désactiver** au niveau du compte (défense en profondeur) — le conteneur documents est privé, mais le garde-fou doit être posé.

Recommandations de sécurité (Microsoft Defender / Advisor) — extrait réel :

>_ console

Impact	Recommandation
High	Machines should be configured to periodically check for missing updates
High	Microsoft Defender for Resource Manager should be enabled
High	Microsoft Defender CSPM should be enabled
High	Microsoft Defender for Storage should be enabled
High	Microsoft Defender for servers should be enabled
High	There should be more than one owner assigned to subscriptions
Medium	Email notification to subscription owner for high severity alerts

Les plans **Microsoft Defender for Cloud** (CSPM, servers, storage) ne sont **pas activés** et les VM ne vérifient pas leurs **mise à jour système** : ce sont les axes de durcissement prioritaires côté plateforme.

7.5 Matrice de risques sécurité

Risque	Impact	Probabilité	Mesure corrective
Storage : accès public blob autorisé (allowBlobPublicAccess=true)	Élevé	Moyenne	Désactiver l'accès public (--allow-blob-public-access false), auditer les conteneurs
IP publiques directes sur les 2 VM	Élevé	Moyenne	Supprimer les IP des VM, administrer via Azure Bastion ; ne garder que l'IP du Load Balancer
Droits Owner larges (compte unique tout-puissant)	Élevé	Faible	Moindre privilège (Reader/Contributor), revue régulière des rôles, MFA
Microsoft Defender non activé (CSPM / servers / storage)	Moyen	Élevée	Activer les plans Defender for Cloud pour la détection et la posture
Mises à jour système non vérifiées	Moyen	Moyenne	Activer Azure Update Manager (vérification périodique des correctifs)
Tags incomplets (14 ressources sans Application)	Moyen	Élevée	Imposer la politique de tags via Azure Policy
SSH (22) exposé sur Internet	Moyen	Faible	Déjà restreint à <IP_ADMIN>/32 ; cible : Bastion / accès <i>just-in-time</i>

7 risques identifiés (≥ 5 demandés), chacun avec impact, probabilité et mesure corrective. Les risques **élevés** (Storage public, IP de VM, droits Owner) sont à traiter en priorité.

7.6 Points forts déjà en place

La revue n'identifie pas que des faiblesses : plusieurs **contrôles essentiels sont déjà appliqués** — SSH restreint à l'IP admin (jamais 0.0.0.0/0), conteneur de stockage **privé**, **TLS 1.2 + HTTPS-only + chiffrement au repos**, **logs d'activité disponibles** (raccordés au workspace), aucun secret versionné (terraform.tfvars/tfstate exclus). Le socle est sain ; les renforcements portent surtout sur l'**exposition réseau**, la **posture Defender** et le **moindre privilège**.

7.7 Captures

Microsoft Azure

Search resources, services, and docs (G+)

Home > Microsoft Defender for Cloud

Microsoft Defender for Cloud | Recommendations

Showing subscription 'Azure for Students'

Environment type: Azure 1, AWS 0, GCP 0, GitHub 0, AzureDevOps 0, GitLab 0, Docker Hub 0, JFrog 0

We are looking for your feedback! Share with us your thoughts about the new recommendations experience. [Click here to provide feedback >](#)

New: Individual recommendations now appear alongside grouped recommendations. You may see more findings, with clearer visibility and better prioritization. [Learn more](#)

All Misconfigurations Vulnerabilities Secrets

0 Critical 0 High 0 Medium 0 Low 0 Active attack paths 0 Overdue recommendations

Search by title / resource Status == 3 selected Risk factors == All Risk level == All Recommendation maturity == All Add View: Flat list By Title By Resource

Risk level	Title	Affected resource	Risk factors	Attack paths	Recommendation owner
Not evaluated	Azure Backup should be enabled for virtual machines	vm-shopeasy-dev-web-2	Microsoft Defender CSPM should be enabled	Microsoft Defender for Resource Manager should be enabled	Microsoft Defender for servers should be enabled
Not evaluated	Azure Backup should be enabled for virtual machines	vm-shopeasy-dev-web-1	Microsoft Defender CSPM should be enabled	Microsoft Defender for Resource Manager should be enabled	Microsoft Defender for servers should be enabled
Not evaluated	Email notification for high severity alerts should be e...		Microsoft Defender CSPM should be enabled	Microsoft Defender for Resource Manager should be enabled	Microsoft Defender for servers should be enabled
Not evaluated	Email notification to subscription owner for high sev...		Microsoft Defender CSPM should be enabled	Microsoft Defender for Resource Manager should be enabled	Microsoft Defender for servers should be enabled
Not evaluated	Machines should be configured to periodically check for miss...	vm-shopeasy-dev-web-1	Microsoft Defender CSPM should be enabled	Microsoft Defender for Resource Manager should be enabled	Microsoft Defender for servers should be enabled
Not evaluated	Machines should be configured to periodically check for miss...	vm-shopeasy-dev-web-2	Microsoft Defender CSPM should be enabled	Microsoft Defender for Resource Manager should be enabled	Microsoft Defender for servers should be enabled
Not evaluated	Microsoft Defender CSPM should be enabled		Microsoft Defender for Resource Manager should be enabled	Microsoft Defender for servers should be enabled	Storage account should use a private link connection
Not evaluated	Microsoft Defender for Resource Manager should be enabled		Microsoft Defender for servers should be enabled	Storage account should use a private link connection	Storage accounts should prevent shared key access
Not evaluated	Microsoft Defender for Storage plan should be enabled with M...		Storage account should use a private link connection	Storage accounts should prevent shared key access	Storage accounts should restrict network access using virtual ne...
Not evaluated	Microsoft Defender for servers should be enabled		Storage accounts should prevent shared key access	Storage accounts should restrict network access using virtual ne...	Subscriptions should have a contact email address fo...

Add or remove favorites by pressing Ctrl+Shift+F

Give us feedback

Recommandations de sécurité Microsoft Defender for Cloud (Defender non activé, mises à jour système, etc.). Portal → Microsoft Defender for Cloud → Recommendations.

Microsoft Azure

Search resources, services, and docs (G+)

Home > Resource Manager | Resource groups > rg-shopeasy-dev > nsg-shopeasy-dev-web

nsg-shopeasy-dev-web | Inbound security rules

Network security group

Network security group security rules are evaluated by priority using the combination of source, source port, destination, destination port, and protocol to allow or deny the traffic. A security rule can't have the same priority and direction as an existing rule. You can't delete default security rules, but you can override them with rules that have a higher priority. [Learn more](#)

Filter by name Port == all Protocol == all Source == all Destination == all Action == all

Priority	Name	Port	Protocol	Source	Destination	Action
100	Allow-HTTP	80	Tcp	Internet	Any	Allow
110	Allow-SSH-Admin	22	Tcp		Any	Allow
65000	AllowVnetInBound	Any	Any	VirtualNetwork	VirtualNetwork	Allow
65001	AllowAzureLoadBalancerInBou...	Any	Any	AzureLoadBalancer	Any	Allow
65500	DenyAllInBound	Any	Any	Any	Any	Deny

Add or remove favorites by pressing Ctrl+Shift+F

Règles entrantes du NSG nsg-shopeasy-dev-web (HTTP depuis Internet, SSH restreint — source admin redactée).

Portal → nsg-shopeasy-dev-web → Inbound security rules.

✓ État après l'atelier

- **8 points de contrôle** vérifiés (RBAC, exposition, NSG, SSH/RDP, chiffrement, accès public Storage, logs, recommandations).
- Constats réels : 1 compte Owner, 2 IP de VM exposées, allowBlobPublicAccess=true, Defender non activé, MAJ non vérifiées — face à des contrôles déjà sains (SSH restreint, stockage privé/chiffré, logs disponibles).
- **Matrice de 7 risques** (impact / probabilité / mesure corrective) — le livrable demandé.
- **Prêt pour l'Atelier 8 — Audit des changements et Activity Log.**

8 Atelier 8 — Audit des changements et Activity Log

🎯 **Objectif** — exploiter les journaux d'activité Azure pour comprendre ce qui a changé dans l'environnement.

📄 **Livrable attendu** — une **fiche d'audit** listant **trois événements significatifs** observés et leur interprétation.

8.1 Exploration de l'Activity Log

>_ bash

```
# Operations de modification réelles (le bruit des evaluations Azure Policy est ecarte)
az monitor activity-log list -g rg-shopeasy-dev --offset 8h --max-events 1000 \
  --query "[?contains(operationName.value,'/write') || contains(operationName.value,'/delete') ||
  ↳ contains(operationName.value,'roleAssignments')].{op:operationName.value, st:status.value}" \
  -o tsv | sort | uniq -c | sort -rn
```

Extrait du résumé (auteur unique louis.scarfone@efrei.net, **264 événements** Succeeded tracés sur la fenêtre) :

>_ console

Microsoft.Compute/virtualMachines/write	(x2)	creation des 2 VM web
Microsoft.Network/loadBalancers/write		creation du Load Balancer
Microsoft.Network/publicIPAddresses/write	(x3)	creation des 3 IP publiques
Microsoft.Network/networkInterfaces/write	(x2)	creation des NIC
Microsoft.Network/virtualNetworks/write + subnets		creation du reseau
Microsoft.Compute/disks/write	(x2)	creation des disques OS
Microsoft.Storage/storageAccounts/write + containers		creation du stockage
Microsoft.Resources/.../resourceGroups/write		creation/maj du groupe (+ tags)
Microsoft.OperationalInsights/workspaces/write		creation du Log Analytics (Atelier 2)
Microsoft.Insights/diagnosticSettings/write	(x3)	raccordement diagnostics (Atelier 2)
Microsoft.Insights/actionGroups/write		creation de l'action group (Atelier 4)
Microsoft.Insights/metricAlerts/write		creation des alertes (Atelier 4)
Microsoft.Insights/metricAlerts/write	Failed (x4)	tentatives d'alerte multi-VM rejetees

8.2 Synthèse par catégorie (travail demandé)

Catégorie	Observé ?	Détail
Créations de ressources	✓ Oui	terraform apply (VM, LB, IP, NIC, VNet, disques, Storage, RG) + workspace, action group, alertes
Suppressions de ressources	— Aucune	La dernière suppression date du nettoyage de fin de TP3 (terraform destroy), hors période
Modifications de configuration	✓ Oui	diagnosticSettings/write (×3), mise à jour des tags du RG (Atelier 6), config du Storage
Changements de droits	— Aucun	Le rôle Owner est hérité de l'abonnement , non modifié aujourd'hui (aucun roleAssignments/write)
Erreurs / opérations échouées	✓ Oui	metricAlerts/write Failed (×4) : tentatives d'alerte sur scope multi-VM rejetées (cf. Atelier 4)

L'Activity Log trace **qui** (louis.scarfone@efrei.net), **quoi** (opération ARM), **quand** (horodatage) et **avec quel résultat** (Started/Accepted/Succeeded/Failed). Le bruit des évaluations **Azure Policy** (policies/audit) est écarté pour ne garder que les changements réels.

8.3 Fiche d'audit — trois événements significatifs

Auteur des trois événements : louis.scarfone@efrei.net.

Événement (opération)	Ressource	Horodatage (UTC)	Statut	Interprétation
Création de VM (virtualMachines/write)	vm-...-web-1/2	2026-06-29 08 :47	Succeeded	Redéploiement de l'infrastructure via terraform apply (21 ressources). Action légitime et attendue (préalable au TP) ; auteur et horodatage tracés.
Création du workspace (workspaces/write)	law-shopeasy-dev	2026-06-29 08 :49	Succeeded	Mise en place de la supervision centralisée (Atelier 2). Changement de configuration structurant pour l'observabilité.
Échec de création d'alerte (metricAlerts/write)	alerte multi-VM (web-1 + web-2)	2026-06-29 09 :09	Failed	Tentative rejetée (scope multi-ressource invalide). Montre que l'Activity Log trace aussi les échecs : précieux pour diagnostiquer une opération qui n'a pas abouti.

Ces trois événements couvrent une **création**, une **modification de configuration** et une **erreur** — les trois axes typiques d'un audit de changements.

8.4 Questions d'analyse

1. Pourquoi l'Activity Log est-il important pour l'audit ?

Parce qu'il constitue la **source de vérité** des opérations de gestion : il enregistre **qui a fait quoi, quand et avec quel résultat** sur les ressources Azure. Il permet de **reconstituer l'historique** des changements, de **détecter une action non autorisée** (création, suppression, modification de droits), de **prouver** qu'une mesure existe, et de répondre aux exigences de **conformité et de contrôle interne**. Sans lui, les changements d'infrastructure seraient **invisibles et non imputables**.

2. Quelle différence entre un log technique et un log d'activité ?

Un **log technique** (système ou applicatif : syslog, logs Nginx, logs d'application) décrit le **fonctionnement interne** d'une ressource ou d'une application — erreurs, requêtes, événements métier (*data-plane*). Un **log d'activité** (Activity Log) trace les **opérations de gestion** réalisées sur les ressources Azure via ARM — création, modification, suppression, changements de droits (*control-plane*). En résumé : le log technique raconte **ce que fait l'application** ; le log d'activité, **ce que l'on fait à l'infrastructure**.

3. Quelle information manque parfois pour reconstituer un incident ?

- Le **contexte applicatif** : l'Activity Log indique « VM modifiée » mais pas pourquoi l'application a planté.
- Les **logs invité / applicatifs** s'ils ne sont **pas centralisés** (syslog, Nginx — non raccordés ici sans Azure Monitor Agent).
- L'**intention** derrière une action : le log dit **qui/quoi/quand**, rarement le **pourquoi**.
- Les **accès data-plane** (lecture/écriture de blobs) qui ne figurent pas dans l'Activity Log de gestion.
- La **corrélation temporelle** entre un changement et un symptôme.

D'où l'intérêt de **centraliser** logs d'activité et logs techniques dans un même workspace (law-shope asy-dev).

4. Comment une DSI peut-elle exploiter ces logs dans une démarche de contrôle interne ?

En **centralisant l'Activity Log** dans Log Analytics (déjà fait : activitylog-to-law) pour : exécuter des **requêtes KQL** régulières, **alerter** sur les opérations sensibles (changements RBAC, règles NSG, suppressions), mener des **revues périodiques** (qui a modifié quoi), **conserver des preuves d'audit** (rétention), **détecter les écarts** (modification manuelle vs IaC) et produire un **reporting de conformité**. Le journal devient un outil de **gouvernance** : traçabilité, imputabilité, détection et preuve.

8.5 Capture

Microsoft Azure Monitor | Activity log

Looking for Log Analytics? In Log Analytics you can search for performance, diagnostics, health logs, and more. [Visit Log Analytics](#)

Search: Quick Insights

Management Group: None Subscription: Azure for Students Event severity: All Timespan: Last 6 hours Resource group: rg-shopeasy-dev Add Filter

21 items.

Operation name	Status	Time	Time stamp	Subscription	Event initiated by
> ⚠️ 'audit' Policy action.	Succeeded	2 hours ago	Mon Jun 29...	Azure for Students	louis.scarfone@efrei.net
> ⚠️ 'audit' Policy action.	Succeeded	2 hours ago	Mon Jun 29...	Azure for Students	louis.scarfone@efrei.net
> ⚠️ Create and update budgets	Failed	2 hours ago	Mon Jun 29...	Azure for Students	louis.scarfone@efrei.net
> ⓘ Update resource group	Succeeded	2 hours ago	Mon Jun 29...	Azure for Students	louis.scarfone@efrei.net
> ⓘ Create or update metric alert	Succeeded	3 hours ago	Mon Jun 29...	Azure for Students	louis.scarfone@efrei.net
> ⓘ Create or update metric alert	Succeeded	3 hours ago	Mon Jun 29...	Azure for Students	louis.scarfone@efrei.net
> ⓘ Create or update action group	Succeeded	3 hours ago	Mon Jun 29...	Azure for Students	louis.scarfone@efrei.net
> ⚠️ Create or update metric alert	Failed	3 hours ago	Mon Jun 29...	Azure for Students	louis.scarfone@efrei.net
> ⚠️ Create or update metric alert	Failed	3 hours ago	Mon Jun 29...	Azure for Students	louis.scarfone@efrei.net
> ⚠️ Create or update metric alert	Failed	3 hours ago	Mon Jun 29...	Azure for Students	louis.scarfone@efrei.net
> ⚠️ Create or update metric alert	Failed	3 hours ago	Mon Jun 29...	Azure for Students	louis.scarfone@efrei.net
> ⓘ 'auditIfNotExists' Policy action.	Succeeded	3 hours ago	Mon Jun 29...	Azure for Students	louis.scarfone@efrei.net
> ⓘ Create or update resource diagnostic setting	Succeeded	3 hours ago	Mon Jun 29...	Azure for Students	louis.scarfone@efrei.net
> ⓘ Create or update resource diagnostic setting	Succeeded	3 hours ago	Mon Jun 29...	Azure for Students	louis.scarfone@efrei.net
> ⓘ Create or update resource diagnostic setting	Succeeded	3 hours ago	Mon Jun 29...	Azure for Students	louis.scarfone@efrei.net
> ⓘ Health Event Resolved	Resolved	3 hours ago	Mon Jun 29...	Azure for Students	louis.scarfone@efrei.net
> ⓘ Health Event Resolved	Resolved	3 hours ago	Mon Jun 29...	Azure for Students	louis.scarfone@efrei.net
> ⓘ Health Event Updated	Updated	3 hours ago	Mon Jun 29...	Azure for Students	louis.scarfone@efrei.net
> ⓘ Health Event Updated	Updated	3 hours ago	Mon Jun 29...	Azure for Students	louis.scarfone@efrei.net
> ⓘ Health Event Updated	Updated	3 hours ago	Mon Jun 29...	Azure for Students	louis.scarfone@efrei.net

Add or remove favorites by pressing Cmd+Shift+F

Journal d'activité du groupe rg-shopeasy-dev (opérations de gestion tracées). Portal → Monitor → Activity log (filtré sur rg-shopeasy-dev).

✓ État après l'atelier

- Activity Log exploité (**264 événements** sur 8 h) : créations, modifications de configuration et **échecs** identifiés; suppressions et changements de droits **absents** sur la fenêtre (cohérent).
- **Fiche d'audit de 3 événements** significatifs (création VM, création workspace, échec d'alerte) avec auteur, horodatage, statut et **interprétation**.
- 4 questions d'analyse traitées (importance de l'audit, log technique vs d'activité, information manquante, exploitation par une DSI).
- **Prêt pour l'Atelier 9 — Plan d'amélioration avant production.**

9 Atelier 9 — Plan d'amélioration avant production (note DSI)

🎯 **Objectif** — transformer les constats techniques du TP4 en **recommandations de décision** pour la DSI.

📦 **Livrable attendu** — une note de recommandations DSI claire, argumentée et exploitable.

Destinataire : Direction des Systèmes d'Information — **Auteurs** : Louis SCARFONE & Maxence BOURRAGUÉ.

9.1 Contexte et objectif

ShopEasy a migré son application de gestion de commandes vers Azure (conception au TP1, industrialisation Terraform au TP2, administration au TP3). Le TP4 fait passer l'environnement d'une logique de **construction** à une logique d'**exploitation** : superviser, alerter, maîtriser les coûts, sécuriser et auditer. Cette note synthétise les constats et propose un **plan d'amélioration priorisé avant toute mise en production**.

9.2 État actuel de l'exploitation

L'environnement (rg-shopeasy-dev, swedencentral) comprend un réseau segmenté, **deux VM web** (B2ats_v2, Nginx) derrière un **Load Balancer** Standard, et un **Storage** privé. La supervision a été initialisée : **Log Analytics law-shopeasy-dev** créé, **Activity Log** et **Storage** raccordés, **2 alertes** actives et un **action group** de notification. Le socle est **sain mais incomplet** : déploiement **mono-zone**, base de données **non déployée**, logs invité/applicatifs **non centralisés**, posture Defender **non activée**.

9.3 Alertes et monitoring proposés

En place : workspace centralisé, alertes **CPU > 70 %** (Moyenne) et **VM indisponible** (Haute) notifiées à ag-shopeasy-ops. **À compléter** : **sonde de disponibilité synthétique** (URL ping test sur l'IP du Load Balancer) pour la disponibilité **réelle vue par l'utilisateur**; **logs Nginx/HTTP** centralisés (Azure Monitor Agent → workspace); alertes **disque/mémoire** (RAM contrainte à 1 Gio) et **crédits CPU** (burstable); enrichissement du **tableau de bord** ShopEasy-Exploitation (créé à l'Atelier 5).

9.4 Analyse FinOps

Coût ≈ **47 \$/mois en 24/7** (prix réels Azure Retail Prices), dont **~92 %** sur **Load Balancer + compute + IP publiques** — le LB et les IP facturent **même à trafic nul**. Environnement **propre** (aucun disque/IP orphelin), mais **14 ressources sans tag Application** et **aucun budget actif**. Leviers : **désallouer les VM** hors usage (et détruire entre séances → ≈ 0), **supprimer les IP des VM** (via Bastion), **généraliser les tags** (Azure Policy), **créer un budget** 50 \$ avec alertes 80 %/100 %.

9.5 Analyse sécurité

Contrôles en place : SSH restreint à l'**IP admin** (jamais 0.0.0.0/0), stockage **chiffré** (TLS 1.2, HTTPS-only) et **privé**, logs d'activité **disponibles**, aucun secret versionné. **Risques identifiés** : accès public du Storage autorisé (allowBlobPublicAccess=true), **2 IP publiques directes** sur les

VM, droits Owner larges (compte unique), Microsoft Defender non activé (CSPM/servers/storage) et mises à jour système non vérifiées.

9.6 Risques résiduels

- **Disponibilité** : déploiement **mono-zone** (pas d'Availability Zones sur *Azure for Students*) et **base de données absente** → pas de SLA élevé tenable en l'état.
- **Observabilité** : logs invité/applicatifs non centralisés → diagnostic applicatif limité.
- **Sécurité** : posture **Defender non activée**, exposition réseau (IP de VM, storage public) à corriger.
- **Coûts** : **budget non créé** (création CLI bloquée) → dérive non détectée tant qu'il n'est pas posé via Cost Management.

9.7 Plan d'action priorisé

Action	Priorité	Responsable	Gain attendu
Compléter les alertes critiques (sonde de disponibilité, disque/mémoire)	Haute	Équipe Cloud	Détection d'incident côté utilisateur
Réduire l'exposition réseau : désactiver l'accès public du Storage + supprimer les IP des VM (Bastion)	Haute	Sécurité / Ops	Réduction de la surface d'attaque
Activer Microsoft Defender for Cloud (CSPM, servers, storage)	Haute	Sécurité	Posture et détection des menaces
Appliquer le moindre privilège (RBAC : Reader/Contributor, MFA)	Haute	Sécurité	Limiter l'impact d'une compromission
Généraliser les tags obligatoires (Azure Policy)	Moyenne	Équipe projet	Pilotage et imputation des coûts
Créer le budget Azure (50 \$/mois, alertes 80 %/100 %)	Moyenne	FinOps	Contrôle des dépenses
Centraliser les logs applicatifs (Azure Monitor Agent → workspace)	Moyenne	Ops	Diagnostic applicatif
Enrichir le tableau de bord DSI (ShopEasy-Exploitation, Atelier 5)	Moyenne	Ops	Suivi opérationnel
Évoluer vers le multi-zone + base managée HA	Basse	Architecture	Disponibilité de production

9.8 Conclusion

L'environnement ShopEasy dispose d'une **base technique exploitable** — supervision initialisée, coûts chiffrés, sécurité partiellement maîtrisée, changements auditable — **mais il doit être renforcé avant toute mise en production**. Les priorités sont la **mise en place d'alertes critiques complètes**, la **réduction de l'exposition réseau** (accès public du Storage, IP des VM), l'**application du moindre privilège** et de **Microsoft Defender**, puis la **création d'un budget** et la **formalisation d'un tableau de bord**. Ces actions réduisent le **risque opérationnel**, améliorent la **visibilité de la DSI** et **maîtrisent les coûts cloud**, en s'appuyant sur les quatre piliers d'une plateforme mature : **observabilité, FinOps, sécurité et gouvernance**.

✓ État après l'atelier

- Note de recommandations DSI complète en **8 sections** (contexte, état, monitoring, FinOps, sécurité, risques résiduels, plan d'action, conclusion).
- **Plan d'action priorisé** (9 actions : Priorité / Responsable / Gain attendu) couvrant les axes du TP.
- Synthèse argumentée des Ateliers 1 à 8, exploitable par une équipe technique **et** par la DSI.

10 Quiz de validation

1. Différence entre monitoring et observabilité ?

Le **monitoring** surveille des indicateurs **prédéfinis** pour savoir **si** le système fonctionne (ex. CPU > 85 %). L'**observabilité** vise à comprendre **pourquoi** un système se comporte d'une certaine façon, à partir des signaux qu'il produit (métriques, logs, traces). Le monitoring **constate**, l'observabilité **explique**.

2. À quoi sert Azure Monitor ?

C'est le service **central de supervision** d'Azure : il **collecte, analyse et exploite** les métriques, les logs et les alertes des ressources, et alimente tableaux de bord, requêtes et **alertes actionnables**.

3. Quel est le rôle d'un Log Analytics Workspace ?

Un **espace centralisé** pour stocker, **interroger (KQL)** et **corrélér** les logs et métriques de plusieurs ressources. Base de l'observabilité (ici law-shopeasy-dev, qui reçoit l'Activity Log et les diagnostics du Storage).

4. Pourquoi définir des seuils d'alerte avec prudence ?

Un seuil **trop bas** déclenche sur des variations normales → **fatigue d'alerte** (faux positifs ignorés). Un seuil **trop haut** → **détection tardive** (l'incident est déjà là). Le seuil se cale sur la **baseline** et se lisse sur une **fenêtre** (ex. 5 min).

5. Qu'est-ce qu'un Action Group ?

Il définit **qui est notifié et comment** lorsqu'une alerte se déclenche : e-mail, SMS, webhook, ITSM. Ici ag-shopeasy-ops notifie l'équipe par e-mail.

6. Pourquoi les tags sont-ils importants en FinOps ?

Ils permettent de **ventiler la facture** (application, environnement, **centre de coût**), d'identifier le **responsable** (Owner) et de définir des **budgets ciblés**. Sans tags, les coûts sont **non imputables**.

7. Quel service Azure permet de suivre les coûts ?

Azure Cost Management (analyse des coûts, **budgets**, alertes, **coût prévisionnel**).

8. **Pourquoi une ressource sans tag pose-t-elle un problème ?**
Son coût est **non imputable** (à quelle application/équipe?), on ignore **qui en est responsable** et si elle peut être arrêtée → gouvernance et pilotage des coûts impossibles.
9. **Quel risque présente un port SSH ouvert à Internet ?**
Une exposition **permanente** aux **scans automatisés** et aux **attaques par force brute**, pouvant mener à la **compromission** de la VM. On restreint à l'**IP admin (/32)** ou via **Azure Bastion**.
10. **Que signifie le principe du moindre privilège ?**
Accorder **uniquement les droits strictement nécessaires** pour accomplir une tâche, afin de **limiter l'impact** d'une erreur ou d'un compte compromis. On préfère Reader/Contributor au rôle Owner.
11. **Quel journal permet de suivre les modifications des ressources Azure ?**
L'**Activity Log** (journal d'activité, *control-plane*) : il enregistre **qui a fait quoi, quand et avec quel résultat**.
12. **Pourquoi faut-il surveiller les droits RBAC ?**
Des **droits excessifs** (trop d'owner) augmentent l'**impact** d'une erreur ou d'une compromission. Surveiller le RBAC détecte les **écarts au moindre privilège** et les **attributions non légitimes**.
13. **Citez deux métriques utiles pour une VM.**
Percentage CPU (saturation calcul) et **Available Memory Bytes** (mémoire). (*Aussi : CPU Credits Remaining pour le burstable, Network In/Out, VmAvailabilityMetric.*)
14. **Citez deux recommandations de sécurité.**
Restreindre les ports d'administration (SSH/RDP à une IP ou via Bastion) et **désactiver l'accès public du Storage**. (*Aussi : activer Defender for Cloud, moindre privilège, MFA.*)
15. **Pourquoi une alerte doit-elle être associée à une procédure d'action ?**
Pour être **actionnable**. Sans **procédure** (runbook : quoi vérifier, qui contacter, quelle action), le destinataire reçoit un signal **sans savoir quoi faire** → perte de temps, alerte ignorée. La procédure **réduit le MTTR**.
16. **Différence entre coût constaté et coût prévisionnel ?**
Le **coût constaté** est la dépense **réelle déjà facturée** (historique). Le **coût prévisionnel** (*forecast*) est une **projection** de la dépense à venir : il permet d'**anticiper un dépassement avant qu'il survienne**.
17. **Pourquoi le chiffrement ne suffit-il pas à sécuriser une ressource ?**
Le chiffrement protège les données **au repos et en transit**, mais **pas** contre un **accès public** mal configuré, des **droits excessifs**, un **port exposé** ou l'**absence de logs**. La sécurité est **multi-couches** : réseau, identité, configuration, audit.
18. **Quel est l'intérêt d'un tableau de bord pour une DSI ?**
Offrir une **vue synthétique de pilotage** : le service fonctionne-t-il, coûte-t-il trop cher, est-il sécurisé, que corriger en priorité ? Il sert à **décider**, pas seulement à afficher des courbes.
19. **Qu'est-ce qu'une dérive de coût cloud ?**
Une **augmentation non maîtrisée** de la dépense, souvent due à des **ressources oubliées, surdimensionnées ou facturées à vide** (Load Balancer, IP) et à l'**absence de budget/tags**. On la découvre **trop tard, sur la facture**.
20. **Donnez trois actions prioritaires avant une mise en production.**
1) **Activer des alertes critiques** (disponibilité, CPU, VM indisponible). 2) **Réduire l'exposition et appliquer le moindre privilège** (désactiver l'accès public du Storage, supprimer les IP des VM, RBAC restreint, Defender). 3) **Maîtriser les coûts** (budget avec alertes, tags obligatoires). (*Compléments : centraliser les logs, dashboard, multi-zone.*)

🎉 **Fin du dossier de rendu — TP4 Monitoring, FinOps & Sécurité Azure**

ShopEasy — Louis SCARFONE & Maxence BOURRAGUÉ — Bloc 4 · Cloud Computing